Chapter 3 / Capítulo 3

Case study / Caso de estudio: Wonderwheels

Source / Fuente: CISA Official Review Manual, ISACA. Material proporcionado por el usuario. Traducción no oficial. Se incluyen las explicaciones completas de A, B, C y D. Los guiones son explicaciones propias para responder oralmente, no citas del manual.

English: Wonderwheels is a major national retailer specializing in outdoor sports, hunting, fishing and camping, including a wide variety of all-terrain vehicles (ATVs), which inspired its name. The enterprise has operations currently based in the United States and has a long-term business plan to expand its retail centers to selected parts of the [sentence incomplete in the supplied text; the answer key identifies the EU].

Español: Wonderwheels es una importante cadena minorista nacional especializada en deportes al aire libre, caza, pesca y campamento. Ofrece una amplia variedad de vehículos todoterreno (ATV), que inspiraron su nombre. Actualmente opera en Estados Unidos y tiene un plan empresarial a largo plazo para expandir sus centros de venta a determinadas regiones. [La frase del archivo adjunto está incompleta; la clave de respuestas identifica a la Unión Europea como el destino de la expansión.]

English: As part of ongoing current operations, management has asked an internal IS auditor to review the enterprise readiness for complying with requirements for protecting cardholder information. This is meant to be a high-level overview of where the firm stands and not a point-by-point review of its compliance with the specific standard (which would be undertaken as a separate engagement later in the year).

Español: Como parte de las operaciones actuales, la dirección ha solicitado a un auditor interno de sistemas de información (SI) que revise la preparación de la empresa para cumplir los requisitos de protección de la información de los titulares de tarjetas. Se busca una evaluación general de la situación, no una revisión punto por punto del cumplimiento de la norma específica; esta se realizará en un encargo independiente más adelante en el año.

English: During the initial assessment, the IS auditor learned the following information:

Español: Durante la evaluación inicial, el auditor de SI obtuvo la siguiente información:

English: POS register encryption. The retailer uses wireless POS registers that connect to application servers located at each store. These registers use wired equivalent protection (WEP) encryption.

Español: Cifrado de las cajas de punto de venta (POS). La empresa utiliza cajas POS inalámbricas conectadas a servidores de aplicaciones ubicados en cada tienda. Estas cajas utilizan cifrado WEP.

English: POS local application server locations. The POS application server, usually located in the middle of the customer service area at each store, forwards all sales data over a frame relay network to database servers at the Wonderwheels corporate headquarters, with strong encryption applied to the data. The data are then sent over a virtual private network (VPN) to the credit card processor for approval of the sale.

Español: Ubicación de los servidores locales de aplicaciones POS. El servidor de aplicaciones POS, generalmente ubicado en medio del área de atención al cliente de cada tienda, envía todos los datos de ventas mediante una red Frame Relay a los servidores de bases de datos de la sede corporativa de Wonderwheels, aplicando un cifrado robusto. Después, los datos se envían por una red privada virtual (VPN) al procesador de tarjetas de crédito para aprobar la venta.

English: Enterprise database locations. Enterprise databases are located on a protected, screened subnet of the enterprise local area network.

Español: Ubicación de las bases de datos empresariales. Se encuentran en una subred protegida y filtrada de la red de área local de la empresa.

English: Sales data distribution. Weekly aggregated sales data, by product line, are copied as-is from the enterprise databases to magnetic media and mailed to a third party for analysis of buying patterns.

Español: Distribución de datos de ventas. Los datos agregados semanales de ventas, por línea de producto, se copian sin modificaciones desde las bases de datos empresariales a medios magnéticos y se envían por correo postal a un tercero para analizar los patrones de compra.

English: Current ERP system compliance. The current state of the enterprise ERP system is such that it may be out of compliance with newer laws and regulations. During the initial assessment, the IS auditor determined that the ERP system does not adhere to the EU General Data Protection Regulation (GDPR).

Español: Cumplimiento del sistema ERP actual. El sistema de planificación de recursos empresariales (ERP) podría incumplir leyes y regulaciones recientes. Durante la evaluación inicial, el auditor determinó que el ERP no cumple el Reglamento General de Protección de Datos de la Unión Europea (RGPD, o GDPR en inglés).

English: Additionally, Wonderwheels database software has not been patched in over two years, due to a few factors:

Español: Además, el software de bases de datos de Wonderwheels no ha recibido parches durante más de dos años, debido a los siguientes factores:

English: • Vendor support for the database package was dropped because it was acquired by a competitor and its remaining business was refocused to other software services.

Español: • El proveedor dejó de brindar soporte al paquete de bases de datos tras ser adquirido por un competidor y reorientar el negocio restante hacia otros servicios de software.

English: • Wonderwheels management implemented plans to upgrade to a new database package. The upgrade is underway; however, it is taking longer than anticipated.

Español: • La dirección puso en marcha planes para migrar a un nuevo paquete de bases de datos. La actualización está en curso, pero tarda más de lo previsto.

English: Regarding the database upgrade, sizeable customizations were anticipated and are being carried out with a phased approach of partial deliverables. These deliverables are released to users for pilot usage on real data and actual projects. Concurrently, design and programming of the next phase are ongoing.

Español: Para la actualización se anticiparon personalizaciones considerables, que se están realizando por fases con entregables parciales. Estos entregables se proporcionan a los usuarios para su uso piloto con datos reales y proyectos reales. Al mismo tiempo, continúa el diseño y la programación de la siguiente fase.

English: In spite of positive initial test results, the internal audit group has voiced that it has not been included in key compliance decisions regarding the configuration and testing of the new system.

Español: A pesar de los resultados positivos de las pruebas iniciales, el grupo de auditoría interna ha señalado que no ha participado en decisiones clave de cumplimiento relacionadas con la configuración y las pruebas del nuevo sistema.

English: In addition, operational transactions are often queued, or hang during execution, and, with increasing frequency, data are corrupted in the database. Additional problems have shown up: errors already corrected have started occurring again, and functional modifications already tested tend to present other errors. The project, already late, is now in a critical situation.

Español: Además, las transacciones operativas suelen quedar en cola o bloquearse durante su ejecución, y los datos de la base de datos se corrompen con una frecuencia creciente. Han surgido otros problemas: reaparecen errores que ya se habían corregido y las modificaciones funcionales que ya se habían probado tienden a presentar nuevos errores. El proyecto, que ya estaba retrasado, se encuentra ahora en una situación crítica.

Question 1 / Pregunta 1

English: Which of the following presents the MOST significant risk to the retailer?

A. Database patches are severely out of date.

B. Wireless POS registers use WEP encryption.

C. Credit cardholder information is sent over the Internet.

D. Aggregate sales data are mailed to a third party.

Español: ¿Cuál de las siguientes situaciones representa el riesgo MÁS significativo para la empresa minorista?

A. Los parches de la base de datos están muy desactualizados.

B. Las cajas POS inalámbricas utilizan cifrado WEP.

C. La información de los titulares de tarjetas de crédito se envía por Internet.

D. Los datos agregados de ventas se envían por correo postal a un tercero.

Correct answer / Respuesta correcta: B

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Unpatched database servers are located on a screened subnet; this mitigates the risk to the enterprise.

Español: Los servidores de bases de datos sin parches están ubicados en una subred filtrada; esto mitiga el riesgo para la empresa.

B. Correct / Correcta

English: Use of WEP encryption presents the most significant risk because WEP uses a fixed secret key that is easy to break. Transmission of credit cardholder information by wireless registers is susceptible to interception and presents a very serious risk.

Español: El uso del cifrado WEP presenta el riesgo más significativo porque emplea una clave secreta fija que es fácil de vulnerar. La transmisión de información de los titulares de tarjetas de crédito desde las cajas inalámbricas puede ser interceptada y representa un riesgo muy grave.

C. Incorrect / Incorrecta

English: Sending credit cardholder data over the Internet is less of a risk because strong encryption is being used.

Español: Enviar datos de los titulares de tarjetas de crédito por Internet representa un riesgo menor porque se utiliza cifrado robusto.

D. Incorrect / Incorrecta

English: Because the sales data being sent to the third party are aggregate data, no cardholder information should be included.

Español: Como los datos de ventas enviados al tercero son agregados, no deberían incluir información de los titulares de tarjetas.

Suggested speaking script / Guion sugerido

English: I would choose B because WEP provides weak protection for the wireless connection. An attacker could intercept cardholder information, making this the most significant risk among the options.

Español: Elegiría la B porque WEP ofrece una protección débil para la conexión inalámbrica. Un atacante podría interceptar la información de las tarjetas, por eso es el riesgo más significativo entre las opciones.

Question 2 / Pregunta 2

English: Based on the case study, which of the following controls is the MOST important to implement?

A. POS registers should use two-factor authentication, with enforced complex passwords.

B. Wireless access points should use Media Access Control (MAC) address filtering.

C. The current ERP system should be patched for compliance with the GDPR.

D. Aggregate sales data should be anonymized and encrypted prior to distribution.

Español: Según el caso de estudio, ¿cuál de los siguientes controles es el MÁS importante de implementar?

A. Las cajas POS deben utilizar autenticación de dos factores y exigir contraseñas complejas.

B. Los puntos de acceso inalámbricos deben utilizar filtrado de direcciones de control de acceso al medio (MAC).

C. El sistema ERP actual debe recibir parches para cumplir el RGPD.

D. Los datos agregados de ventas deben anonimizarse y cifrarse antes de su distribución.

Correct answer / Respuesta correcta: D

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: According to the case study, it is unclear whether the POS registers already use two-factor authentication. It is known that aggregate sales data are copied onto other media as-is, without any controls, for external distribution.

Español: Según el caso, no está claro si las cajas POS ya utilizan autenticación de dos factores. Lo que sí se sabe es que los datos agregados de ventas se copian sin modificaciones a otros medios y sin controles para su distribución externa.

B. Incorrect / Incorrecta

English: According to the case study, it is unclear whether the wireless access points use MAC address filtering. It is known that aggregate sales data are copied onto other media as-is, without any controls, for external distribution.

Español: Según el caso, no está claro si los puntos de acceso inalámbricos utilizan filtrado de direcciones MAC. Lo que sí se sabe es que los datos agregados de ventas se copian sin modificaciones a otros medios y sin controles para su distribución externa.

C. Incorrect / Incorrecta

English: Compliance with the GDPR, although important, is not the most important due to the current operations being only in the United States, and the potential for expansion into the EU is a long-term vision for the enterprise.

Español: El cumplimiento del RGPD, aunque es importante, no es la prioridad principal, dado que las operaciones actuales se realizan únicamente en Estados Unidos y la posible expansión a la Unión Europea es una visión a largo plazo de la empresa.

D. Correct / Correcta

English: It is unclear whether sales data are secure and free of personally identifiable information, such as credit card information and Social Security numbers. This presents the most significant risk and should be addressed.

Español: No está claro si los datos de ventas están protegidos y libres de información de identificación personal, como datos de tarjetas de crédito y números de Seguro Social. Esto representa el riesgo más significativo y debe abordarse.

Suggested speaking script / Guion sugerido

English: I would choose D because the sales data are copied and sent outside the company without controls. Anonymization protects personal information, and encryption protects the data if the media are intercepted.

Español: Elegiría la D porque los datos de ventas se copian y se envían fuera de la empresa sin controles. La anonimización protege la información personal y el cifrado protege los datos si alguien intercepta los medios.

Question 3 / Pregunta 3

English: In the preliminary report to management, regarding the state of the database upgrade, which of the following is MOST important for the IS auditor to include?

A. Internal audit should be included among the steering committee approvals.

B. There is a possibility that the new database may not be compatible with the existing ERP solution.

C. An ERP upgrade and/or patch is required to ensure updated database compatibility.

D. Internal audit should be able to review the upgraded database to ensure compliance with Payment Card Industry Data Security Standard (PCI DSS).

Español: En el informe preliminar a la dirección sobre el estado de la actualización de la base de datos, ¿qué es lo MÁS importante que debe incluir el auditor de SI?

A. La auditoría interna debe participar en las aprobaciones del comité directivo.

B. Existe la posibilidad de que la nueva base de datos no sea compatible con la solución ERP actual.

C. Se requiere una actualización o un parche del ERP para asegurar la compatibilidad con la base de datos actualizada.

D. La auditoría interna debe poder revisar la base de datos actualizada para asegurar el cumplimiento del Estándar de Seguridad de Datos de la Industria de Tarjetas de Pago (PCI DSS).

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: If internal audit is part of the steering committee, then it will have a say in the compliance and security-related controls to be included in production releases.

Español: Si la auditoría interna forma parte del comité directivo, tendrá participación en las decisiones sobre los controles de cumplimiento y seguridad que se incluirán en las versiones puestas en producción.

B. Incorrect / Incorrecta

English: Ensuring database compliance is an operational responsibility and not an audit responsibility.

Español: Garantizar el cumplimiento de la base de datos es una responsabilidad operativa, no una responsabilidad de auditoría.

C. Incorrect / Incorrecta

English: Compatibility with existing architecture must be a function of the database implementation project team as a whole, which can include internal audit and also includes operations. Therefore, it is not the best answer choice.

Español: La compatibilidad con la arquitectura existente debe ser responsabilidad del equipo de implementación de la base de datos en su conjunto, que puede incluir a auditoría interna y también incluye a operaciones. Por ello, no es la mejor respuesta.

D. Incorrect / Incorrecta

English: Although it is important that the upgraded database solution be compliant with all regulations affecting the enterprise, such a review should not be limited to one regulation. Therefore, it is not the best choice of those answers provided.

Español: Aunque es importante que la solución de base de datos actualizada cumpla todas las regulaciones que afectan a la empresa, la revisión no debe limitarse a una sola norma. Por ello, esta no es la mejor de las opciones proporcionadas.

Nota del original: La explicación de B trata del cumplimiento de la base de datos, mientras que la opción B trata de la compatibilidad con el ERP. Se conserva la diferencia del material proporcionado.

Suggested speaking script / Guion sugerido

English: I would choose A because internal audit was excluded from key decisions. Its participation in the steering committee would help ensure that security and compliance controls are considered before releases go into production.

Español: Elegiría la A porque auditoría interna quedó fuera de decisiones importantes. Su participación en el comité directivo ayudaría a que los controles de seguridad y cumplimiento se consideren antes de poner las versiones en producción.

Question 4 / Pregunta 4

English: To contribute more directly to help address the problems around the database upgrade, the IS auditor should:

A. Review the validity of the functional project specifications as the basis for an improved software baselining definition.

B. Propose to be included in the project team as a consultant for QC of deliverables.

C. Research the problems further to identify root causes and define appropriate countermeasures.

D. Contact the project leader, discuss the project plans and recommend redefining the delivery schedule using the PERT methodology.

Español: Para contribuir de manera más directa a resolver los problemas de la actualización de la base de datos, el auditor de SI debería:

A. Revisar la validez de las especificaciones funcionales del proyecto como base para mejorar la definición de la línea base del software.

B. Proponer su incorporación al equipo del proyecto como consultor de control de calidad (QC) de los entregables.

C. Investigar más los problemas para identificar sus causas raíz y definir medidas correctivas apropiadas.

D. Contactar al líder del proyecto, discutir los planes y recomendar que se redefina el cronograma de entregas mediante la metodología PERT.

Correct answer / Respuesta correcta: C

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Functional project specifications should be executed by users and systems analysts, and not by the auditor.

Español: Las especificaciones funcionales del proyecto deben ser elaboradas por los usuarios y los analistas de sistemas, no por el auditor.

B. Incorrect / Incorrecta

English: To propose to be project consultant for quality would not bring about an essential contribution, because quality is a formal characteristic; whereas, in the current case, the problem is substantial system instability.

Español: Proponer su participación como consultor de calidad del proyecto no aportaría una contribución esencial, porque la calidad es una característica formal, mientras que el problema del caso es una inestabilidad sustancial del sistema.

C. Correct / Correcta

English: The only appropriate action is additional research, even if the apparently technical nature of the problem renders it unlikely that the auditor may find it alone.

Español: La única acción apropiada es investigar más, incluso si la naturaleza aparentemente técnica del problema hace poco probable que el auditor pueda identificarlo por sí solo.

D. Incorrect / Incorrecta

English: To contact the project leader and redesign the schedule of deliveries would not solve the problem. Furthermore, the definition of real causes may sensibly alter the project environment.

Español: Contactar al líder del proyecto y rediseñar el cronograma de entregas no resolvería el problema. Además, la identificación de las causas reales puede modificar considerablemente el contexto del proyecto.

Suggested speaking script / Guion sugerido

English: I would choose C because the project has recurring errors, blocked transactions and corrupted data. The auditor should investigate the root causes before recommending corrective measures; changing the schedule alone would not fix them.

Español: Elegiría la C porque el proyecto tiene errores que reaparecen, transacciones bloqueadas y datos corruptos. El auditor debe investigar las causas raíz antes de recomendar medidas correctivas; cambiar solamente el cronograma no resolvería esos problemas.